



[BIT703 Web Technologies](#) / [Contents](#) / [Topic 8: Databases for web applications](#) / [Information security technologies and standards](#)

Database security best practices 30m

There are six database security best practices to protect a database from cyberattacks. These database security best practices will ensure that the data kept in the database is safe and secure from attacks and data breaches. When using a database, make sure you follow the six security best practices below to keep your data confidential and secure. We will look at each point in more detail below.

- Harden database management systems
- Database activity monitoring
- Encrypt sensitive data
- Perform vulnerability and configuration assessments
- Enforce the principle of least privilege
- Establish security and compliance policies.

Harden database management systems

Database hardening is the process of analysing and configuring a database to address security vulnerabilities by applying security best practices.

The purpose of hardening a database is to protect database systems, including software and hardware components, against cyberattacks. It is vital to have updated software and hardware to withstand malicious and new attacks and threats. A key part of hardening is to eliminate vulnerabilities by reducing the attack surface of the system.

[Skip to main content](#)

Database activity monitoring

Database auditing used to put a heavy strain on performance. Many organisations reduced detail in logs to improve operational efficiency. It is highly recommended to monitor systems with behaviour-based analysis to detect unusual user activity, especially among users with administrative access.

Encrypt sensitive data

Encryption is a critical best practice for database security. Nowadays, businesses and organisations insist on the use of strong encryption to protect their databases in three ways:

- transport layer security (TSL) encryption – should be mandatory for all database connections to protect data in transit
- disk encryption for storage devices used by databases to prevent loss, theft and improper disposal
- column-level encryption to protect the most sensitive data fields within a database table.

Perform vulnerability and configuration assessments

To test database security controls, IT security and compliance teams should perform ongoing assessments through regular vulnerability and configuration audits. These audits provide actionable information about:

- known vulnerabilities experienced by the database management system, the underlying operating system or any integrated component
- misconfigurations that could make the database vulnerable to attack
- violation of government regulations, industry-standard or company-established data security policies.

Enforce the principle of least privilege

A basic concept of network security is to restrict a user's access to the minimum set of privileges required to perform their task. Organisations and businesses must determine to what degree their network access rules on their databases. It is one of the recommended

Skip to main content

practices to restrict access as much as possible and is an important guarantee against internal threats.

Establish security and compliance policies

Without clearly defined security policies and standards, it will be difficult for an organisation to assess compliance and measure progress. Organisations and businesses should formulate strong data security policies. Security and compliance teams need to determine how often policies are updated, who is responsible for the updates, why they are triggering policy changes and who is involved in the policy update approval process. Once any security incident has happened, a post-mortem step should follow, during which policies are evaluated and updated to reflect newly discovered threats.

In the following activities, you will be presented with case studies of security breaches that resulted in people's personal data being stolen. Read through the case study information to find out what happened, how it happened and who was affected, and then answer the questions that follow.



☒ Brighton and Sussex University Hospital NHS Trust

Non-Assessed

[Skip to main content](#)

Brighton and Sussex University Hospital NHS Trust was the subject of a data breach in September 2010 when 232 decommissioned drives packed with patient data were stolen. Read through the case study below to answer the question:

1. **What happened?** - personal data belonging to patients and staff was taken from Brighton General Hospital in September 2010. Brighton and Sussex University Hospital was fined £325,000 over the theft of thousands of patients' data. The sensitive information, which included medical results, was reportedly put up for sale on eBay.
 2. **How?** - the breach occurred after an individual working for the Trust's IT provider was told to destroy hard drives containing patients' data. The individual instead sold the hard drives on eBay. The thief accessed the sensitive data by stealing hard drives that were supposed to have been destroyed during their decommissioning. **We assume the data was unencrypted.**
 3. **How many were affected?** - figures are unclear, but 232 decommissioned drives packed with patient data were stolen.
- If you were a data protection officer, what would be your recommendation(s) for how this NHS Trust could have avoided this data breach?

B	<i>I</i>	<u>U</u>		☰	¹ / ₂ ☰	☰	☰	☰		T ²	T ₂		☐☐☐
												0 / 100 Word Limit	

Save draftSubmit

[Skip to main content](#)



☒ Morrisons supermarket chain

Non-Assessed

Morrisons supermarket chain was the subject of a data breach in 2017, where an internal attack led to the leak of employees' personal information. Read through the case study below to answer the question:

1. **What happened?** - in 2017, the supermarket chain Morrisons fell victim to an internal attack that led to 100,000 employees' personal details being leaked.
 2. **How?** - employee Andrew Skelton leaked the payroll data of Morrisons' entire workforce, including bank account details and salaries. The attack is reported to have cost the supermarket chain £2 million and Skelton is serving eight years for the crime. It seems that this catastrophic breach happened because Morrisons allowed employees too much access to sensitive information.
 3. **How many were affected?** - 100,000 employees
- Discuss what countermeasures should have been taken by Morrisons to prevent this catastrophic breach.

B *I* U | :≡ $\frac{1}{2}$ ≡ ≡≡ ≡≡ ≡≡ | T² T₂ | 

0 / 100 Word Limit

Save draft

Submit

[Skip to main content](#)



☒ Vision Direct

Non-Assessed

[Skip to main content](#)

The online contact lens supplier Vision Direct was the subject of a data breach that compromised the credit card details and personal information of their customers. Read through the case study below to answer the questions:

1. **What happened?** - the European online contact lens supplier Vision Direct was the victim of a hack attack that compromised full credit card details for a number of its customers, as well as their personal information. The attack happened between November 3–8 2018, meaning the data breach lasted for over five days. The compromised data stolen included full name, billing address, email address, password, telephone number and payment card information, which included card number, expiry date and CVV.
 2. **How?** - the hacker stole thousands of sensitive card details and personal information in a cyberattack. This cyberattack happened through the hacker placing a fake Google Analytics script into the website's code to steal personal data. A spokeswoman for Vision Direct told the BBC; 'This particular breach is known as Shoplift and was already known to our technology team, who installed a patch provided by our web platform provider to prevent this form of malware.'
 3. **How many were affected?** - it was identified that 16,300 people potentially had their personal data compromised. It's estimated that around 6,600 customers had their personal information and credit card details compromised, while a further 9,700 people had only their personal information compromised.
- Recommend your best practices for how Vision Direct could have protected customer data to avoid a data breach of this magnitude.

B	<i>I</i>	<u>U</u>		☰	☰ ¹	☰	☰	☰		T ²	T ₂		☐
													0 / 100 Word Limit

Skip to main content

Save draft

Submit



Understanding Cross-Site Request Forgery (CSRF) and Cross-Site Scripting (XSS) vulnerabilities is critical for building secure web applications. Next, we'll look at how to identify, prevent and protect against these common threats.



Thoughts on this page?

